

MÓDULO 2
Arquitecturas de seguridad
y técnicas
Ciberseguridad

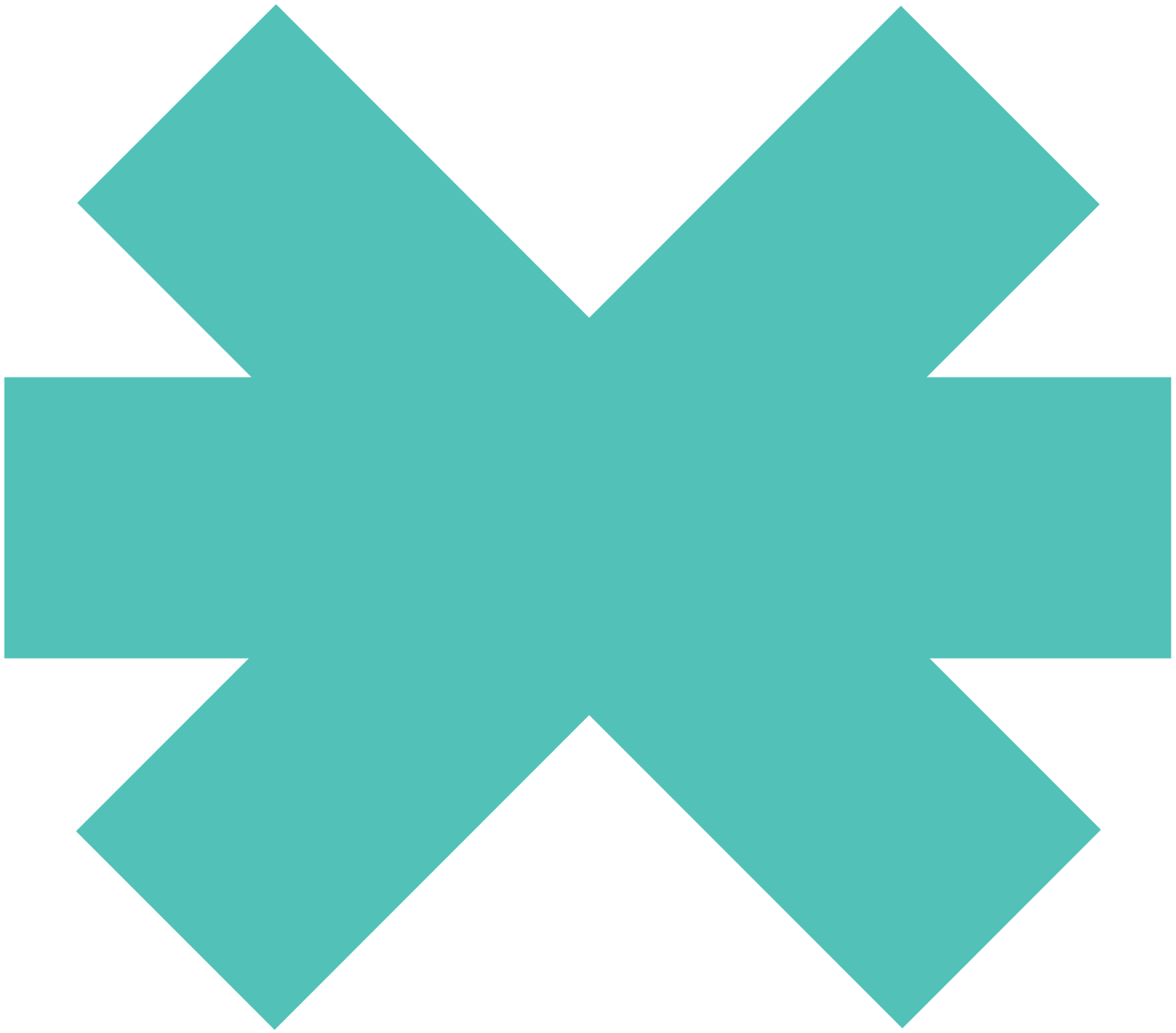
6

Seguridad en sistemas operativos y software



New
Technology
School

Tokio.



6 Seguridad en sistemas operativos y software

Sumario

6.1	Los sistemas operativos	190
6.2	Fuentes de información	191
6.3	Windows	192
6.4	Linux	197
6.5	macOS	202

6.1 Los sistemas operativos

El sistema operativo representa el corazón de cualquier dispositivo informático, desde un ordenador personal hasta un teléfono inteligente o un servidor, actuando como intermediario entre el *hardware* del sistema (procesadores, memoria, dispositivos de entrada y salida...) y las aplicaciones o programas que los usuarios y las usuarias desean utilizar. Este *software* fundamental administra y coordina todos los recursos del sistema, posibilitando el funcionamiento eficiente del dispositivo.

Así, los sistemas operativos gestionan recursos como la memoria RAM, el tiempo de procesamiento o los dispositivos de almacenamiento, entre otros. Del mismo modo, proporcionan la interfaz que permite a los usuarios y las usuarias interactuar con el dispositivo de manera fácil e intuitiva. Asimismo, administran los procesos en ejecución, gestionan la memoria, los archivos y los distintos dispositivos e implementan mecanismos de seguridad.

En definitiva, se trata de una pieza imprescindible en cualquier dispositivo y, por tanto, resulta crucial proteger su integridad frente a las posibles amenazas.

6.2 Fuentes de información

Los sistemas operativos representan un objetivo clave a la hora de obtener información valiosa que pueda ser explotada con fines maliciosos, ya que tanto las organizaciones como los usuarios y las usuarias particulares los utilizan para guardar información de cualquier índole. Por consiguiente, los ciberdelincuentes buscan activamente fuentes de datos dentro de los sistemas operativos que puedan proporcionarles ventajas para llevar a cabo sus actividades ilícitas. Desde los archivos de registro hasta las contraseñas almacenadas, cada fuente de información puede tratarse de un eslabón crucial.

A continuación, nos detendremos en las principales fuentes de información de un sistema operativo a las que un atacante puede acceder, desde los registros que rastrean cada evento del sistema hasta los datos almacenados en caché. Como ya hemos señalado en el tema anterior, de este modo se pretende concienciar de la cantidad de información que puede albergar un sistema y de la importancia crítica que reviste implementar medidas de seguridad y protección en él.

- **Archivos de registro (*logs*).** Los archivos de registro del sistema operativo y de las aplicaciones pueden proporcionar información valiosa sobre las actividades y eventos que ocurren en el sistema, por ejemplo, intentos de inicio de sesión, cambios en la configuración, errores y fallos, etc.
- **Archivos de configuración.** Estos archivos también pueden contener información sensible, como credenciales de acceso, claves de encriptación y rutas de directorios importantes.
- **Base de datos de contraseñas.** Si un atacante obtiene acceso no autorizado a esta base de datos, puede tratar de descifrar las contraseñas de usuarios y cuentas privilegiadas o utilizar técnicas de *hash* inverso para obtenerlas.
- **Metadatos de archivos.** Entre ellos, la información de autor, la fecha de creación y las modificaciones... Por tanto, pueden proporcionar pistas sobre quién creó o modificó un archivo y cuándo.
- **Datos de memoria.** Los atacantes pueden extraer datos como contraseñas almacenadas en caché, claves de sesión y otra información sensible que se alberga temporalmente en la memoria RAM.
- **Información del sistema.** Los detalles sobre el *hardware*, el *software* y la versión del sistema operativo pueden contribuir a que los ciberdelincuentes identifiquen posibles vulnerabilidades y debilidades susceptibles de ser explotadas.
- **Tráfico de red.** Analizando el tráfico de red, un atacante puede obtener información sobre los servicios y puertos abiertos, identificar sistemas vulnerables y capturar datos no cifrados.
- **Archivos temporales y de caché.** Pueden contener información confidencial que resultaría útil para los ciberdelincuentes, como datos de sesión y *cookies*.
- **Errores y mensajes del sistema.** Pueden proporcionar pistas sobre posibles vulnerabilidades o problemas en el sistema susceptibles de ser explotados.

Como podemos comprobar, las fuentes de información derivadas de un sistema operativo son un objetivo primordial para los atacantes, ya que pueden proporcionarles datos valiosos y potencialmente comprometedores.

6.3 Windows

Windows es el sistema operativo distintivo de la compañía Microsoft, basado en una interfaz gráfica de usuario (GUI) y lanzado al mercado en 1985. La historia de Microsoft se inicia con la asociación de Bill Gates y Paul Allen en 1975, si bien la compañía fue formalmente constituida en 1981. Por aquel entonces, Bill Gates apostó decididamente por invertir en la interfaz gráfica del sistema operativo, que hoy en día es el más utilizado a nivel de usuario en todo el mundo.

Windows es un sistema operativo de pago que ha adoptado numerosas versiones a lo largo de su historia, caracterizada por los importantes esfuerzos que ha realizado Microsoft para mejorar su seguridad. Con todo, en sus primeras versiones, la seguridad no era una prioridad o no se le concedía la misma importancia durante el proceso de diseño. Sin embargo, con el tiempo, la compañía ha dedicado considerables recursos para reforzar esta característica implementando actualizaciones regulares y adoptando enfoques más proactivos para abordar los diferentes desafíos de seguridad.

Hoy en día, Windows sigue siendo ampliamente utilizado en una gran variedad de dispositivos, desde equipos de escritorio y portátiles hasta *tablets* y móviles. Su popularidad se debe, en gran parte, a su facilidad de uso, a su compatibilidad con una extensa gama de aplicaciones y a su continua adaptación a las necesidades cambiantes de los usuarios y las usuarias y del sector tecnológico.

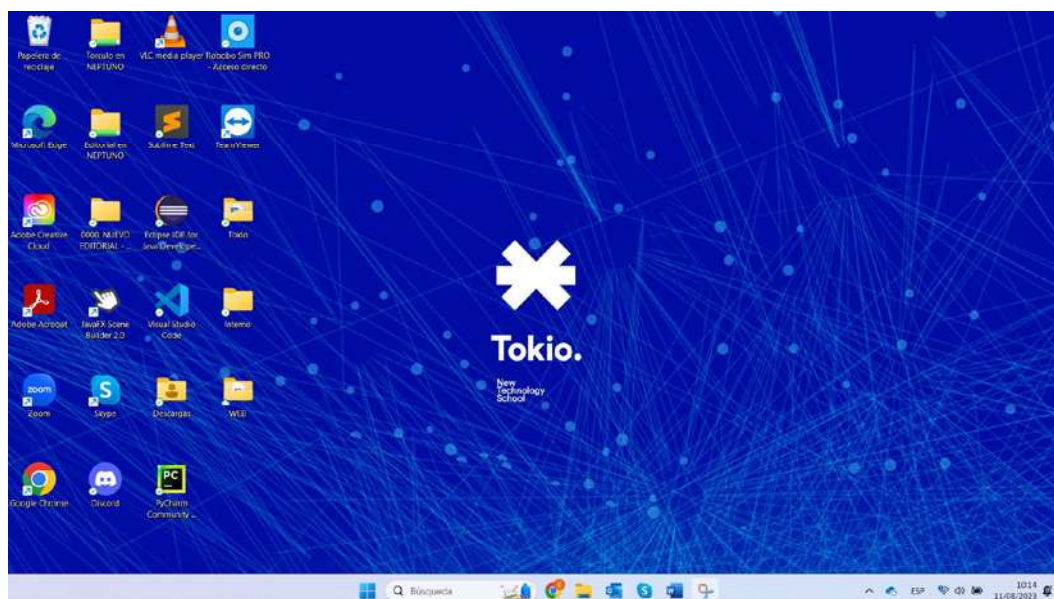


Figura 35. Interfaz de Windows

Las mejoras que Windows ha realizado en las últimas actualizaciones, sobre todo en Windows 11, se pueden dividir en dos categorías, clientes y servidores.

En la parte de **clientes**, podemos destacar las siguientes:

- Windows Hello, que permite iniciar sesión de usuario mediante reconocimiento facial.
- Herramientas para limitar el alcance de una posible intrusión a través de vulnerabilidades en las aplicaciones. En este sentido, recurre a "jaulas lógicas", que impiden la escalada de un atacante desde la aplicación al sistema por medio de módulos de cifrado TPM, que ya resultan bastante comunes en los sistemas del mercado de consumo.
- Elementos nativos de Microsoft Edge que contribuyen a proteger la privacidad de la navegación y que bloquean los intentos de rastrear datos desde webs maliciosas.
- Opción de activar copias de seguridad en OneDrive para salvar los datos frente a fallos de todo tipo, lo que permite recuperar la información incluso tras haber perdido el control del equipo.
- Protección de las comunicaciones mediante nuevos protocolos y mejoras en los ya existentes, donde prima la seguridad sobre otros aspectos, si bien se procura preservar cierto compromiso de cara al mantenimiento de la velocidad de acceso a los servicios.
- Seguimiento, protección y bloqueo de aplicaciones, juegos, etc. en base a horarios, dispositivos y otros perfiles por medio de Microsoft Family Safety.

En cuanto a la parte de **servidores**, podemos señalar las siguientes:

- Mejoras en la seguridad de las comunicaciones internas, tanto a nivel de *host* como de virtualización.
- Mejoras en los protocolos de gestión de AD DS (*Active Directory Domain Services*).
- Máquinas virtuales blindadas (*Shield Virtual Machines*), cuyo objeto es imposibilitar el acceso a la información que contienen por cualquier medio.
- Mejoras en la gestión de contraseñas del dominio, incluyendo las famosas PSO (*Password Setting Object*).
- Mejoras en la gestión de accesos y limitación de estos con JE, JIT y PAM (*Just Enough, Just In Time y Privileged Access Management*, respectivamente).
- Mejoras en los filtros destinados a prevenir el *malware* y otras amenazas mediante herramientas como AppLocker, Device Guard y el propio Windows Defender.
- Gestión de los *logs* de sistema operativo, que ha experimentado una gran transformación con la introducción de las auditorías avanzadas y con el potente Log Analytics.
- Ligado a lo anterior, cabe mencionar también las ventajas de *Advanced Threat Analytics* (ATA), que supuso una verdadera revolución en Windows Server 2016 y que se ha convertido en un auténtico monstruo en versiones posteriores, tirando sobre todo de la potencia de cómputo de la nube.
- Protección de diversos servicios, como DNS, DHCP, SMB, etc.

- BitLocker, que contribuye a proteger los datos alojados en nuestros dispositivos y en los servidores.
- El *firewall* que, si bien no supone la mejor defensa frente a los ataques, sí representa una capa adicional de protección cuando se combina con los *firewalls* perimetrales de terceros.

A continuación, proporcionaremos una serie de consejos dirigidos a reforzar la seguridad en Windows, tanto a nivel de usuario como de empresa:

- Activar las opciones de seguridad del sistema operativo.
- Programar escaneos periódicos del antivirus.
- Habilitar la restauración del sistema en caso de desastre.
- Actualizar el equipo a la última versión.
- Usar cuentas locales en lugar de cuentas de *login* en la nube
- Analizar los *drivers* que se van a instalar.
- No conectarse a redes wifi públicas.
- Cifrar el disco duro.
- Activar el arranque seguro.

Versiones de Windows

Desde su nacimiento en 1985, Windows ha lanzado 12 versiones principales, mejorando con cada una de ellas diferentes aspectos, entre ellos, la seguridad del sistema:

- **Windows 1.0 (1985).** Primera versión de Windows, que no contó con demasiada relevancia en términos de vulnerabilidades, ya que su uso era bastante limitado y no estaba tan conectado a internet como las versiones posteriores.
- **Windows 2.0 (1987).** Su adopción fue limitada y, aunque todavía no permanecía tan conectada a internet, su seguridad presentaba un desarrollo escaso en comparación con las versiones modernas.
- **Windows 3.x (1990).** Esta serie incluía versiones como Windows 3.0, Windows 3.1 y Windows 3.11 que, si bien introdujeron mejoras en la interfaz de usuario, no priorizaban la seguridad y no habían sido diseñadas para permanecer tan conectadas a internet como las versiones siguientes.
- **Windows 95/98/ME (1995-2000).** También contaban con limitaciones en términos de seguridad en comparación con las versiones posteriores y, además, habían sido concebidas para desplegarse en una amplia variedad de *hardware*, lo que a menudo implicaba compromisos en la seguridad.
- **Windows NT 3.1/3.5/3.51/4.0 (1993-1996).** Serie separada de Windows destinada al uso empresarial y más centrada en la seguridad que las versiones de consumo, aunque presentaba sus propias vulnerabilidades.

- **Windows 2000 (2000).** Basada en la tecnología Windows NT, Windows 2000 fue una versión relevante para entornos empresariales donde se mejoró la seguridad en comparación con las versiones anteriores, si bien todavía persistían ciertas vulnerabilidades.
- **Windows XP (2001).** Versión muy popular que contó con una amplia adopción, aunque también fue conocida por sus problemas de seguridad, pues a medida que el uso de internet se generalizaba, XP se convirtió en el objetivo de muchos ataques.
- **Windows Vista (2007).** Introdujo mejoras en la seguridad en comparación con XP, pero también fue cuestionada por sus problemas de compatibilidad y rendimiento.
- **Windows 7 (2009).** Mejoró la seguridad en comparación con Vista y contó con una buena aceptación por parte de los usuarios y las usuarias.
- **Windows 8/8.1 (2012-2013).** Estas versiones presentaban cambios significativos en la interfaz de usuario, pero no destacaban especialmente en términos de vulnerabilidades.
- **Windows 10 (2015).** De cara al desarrollo de esta versión, Microsoft realizó esfuerzos significativos para mejorar la seguridad, implementando varias características avanzadas.
- **Windows 11 (2021).** Se trata de la última versión de Windows e incorpora mejoras en seguridad dirigidas a reducir las posibilidades de *exploits* y de ciberataques con respecto a Windows 10.

Vulnerabilidades

Como todos los sistemas, Windows posee vulnerabilidades en todas sus versiones. Además, al tratarse del sistema operativo más usado del mundo, constituye un destacado objetivo para los atacantes. A continuación, vamos a describir algunas de esas vulnerabilidades:

- **Vulnerabilidad Zerologon.** Se corresponde con CVE-2020-1472 y fue detectada en agosto de 2020, considerándose una vulnerabilidad crítica. Se debe a una falla técnica en el esquema de autenticación criptográfica del Protocolo Remoto de Netlogon, responsable de la autenticación de usuarios en redes basadas en dominios. De este modo, un atacante con acceso de cliente puede modificar correctamente la contraseña del controlador de dominio y manejar todos los servicios del directorio activo de la red.
- **BlueKeep.** Identificador CVE-2019-0708, que afecta al protocolo RDP (*Remote Desktop Service*) de Windows 2003, XP, Windows 7, Windows Server 2008 y 2008 R2. La vulnerabilidad *BlueKeep* resulta muy peligrosa por varias razones: en primer lugar, porque RDP es una herramienta incluida por defecto en Windows y muy utilizada tanto en empresas como en entornos domésticos para controlar ordenadores de forma remota; en segundo lugar, porque permite a cualquier pirata informático ejecutar código en los ordenadores vulnerables; y en tercer lugar, porque posee una naturaleza de gusano, es decir, un solo ordenador vulnerable pueda buscar en la red más ordenadores vulnerables y explotarlos de forma automática sin necesidad de realizar ninguna otra acción, algo similar a lo sucedido con *WannaCry*.
- **Adobe Flash CVE-2018-4878.** Adobe Flash ha evidenciado numerosas vulnerabilidades en los últimos años, tratándose, sin duda, de una de las herramientas que ha requerido más parches y que ha afectado a un mayor número de usuarios y usuarias de Windows 10. Una de ellas fue la vulnerabilidad conocida como

CVE-2018-4878, que permitiría a un atacante ejecutar código de manera arbitraria. De esta forma, podía ejecutar todo tipo de comandos en nuestro sistema y comprometer su seguridad.

- **Administrador de Windows CVE-2015-1769.** Vulnerabilidad que afectó notablemente a los usuarios de Windows 10, incidiendo en el administrador de archivos y permitiendo que un atacante la explotase con tan solo introducir una memoria USB en el equipo. Así, podía lograr una escalada de privilegios y desplegar código malicioso que comprometiese la seguridad del sistema. Nuevamente, estamos ante una vulnerabilidad que fue parcheada en su momento por Microsoft.
- **Vulnerabilidades de Internet Explorer.** Se trata de las vulnerabilidades CVE-2018-8174 y CVE-2016-0189, que afectan a Internet Explorer. Aun cuando hoy en día no es un navegador muy popular, está presente en la mayoría de sistemas con Windows 10.

La primera vulnerabilidad podía afectar a cualquier sistema de Microsoft; sin embargo, la compañía lanzó parches en 2018 para corregirla en todos los sistemas operativos con soporte. Este fallo, conocido también como *Double Kill*, permitiría a un atacante entrar en la memoria virtual del sistema.

La segunda vulnerabilidad, por su parte, posee unas repercusiones similares y explota un fallo en un archivo *VBScript.dll* que no se encuentra actualizado en Windows. En esta ocasión, requiere la descarga de un archivo corrupto.

- **Vulnerabilidades en Microsoft Office.** Como cabía suponer, el programa de ofimática más utilizado del mundo también posee vulnerabilidades. Una de las más representativas sería CVE-2021-40444, una vulnerabilidad de día cero en el motor MSHTML de Internet Explorer, que es un componente del sistema utilizado por las aplicaciones de Microsoft Office para manejar contenido web. Esta vulnerabilidad, que permite ejecutar código malicioso a distancia en los equipos de las víctimas, se informó por primera vez en septiembre de 2021 y afectó a cerca de 5000 personas en el segundo trimestre de 2022, una cifra ocho veces superior a la registrada durante el trimestre anterior.

6.4 Linux

En este apartado, nos ocuparemos de las características del sistema Linux, que cuenta con una amplia variedad de distribuciones para diversas aplicaciones, gran parte de ellas específicamente dirigidas a realizar pruebas de penetración y análisis de seguridad.

Linux es un sistema operativo cuyos inicios se remontan a principios de los años 80 de la mano de Richard Stallman, quien puso en marcha el proyecto GNU con el propósito de crear un sistema operativo compatible con UNIX. Más adelante, en 1985, se creó la Fundación del *Software* Libre y se desarrolló la Licencia Pública de GNU, que permitía la distribución gratuita de este *software*.

En 1991, Linus Torvalds, un estudiante de la Universidad de Helsinki, propuso crear un sistema operativo que se asemejara a UNIX, pero que además resultase compatible con cualquier ordenador, requiriendo como mínimo un procesador i386.

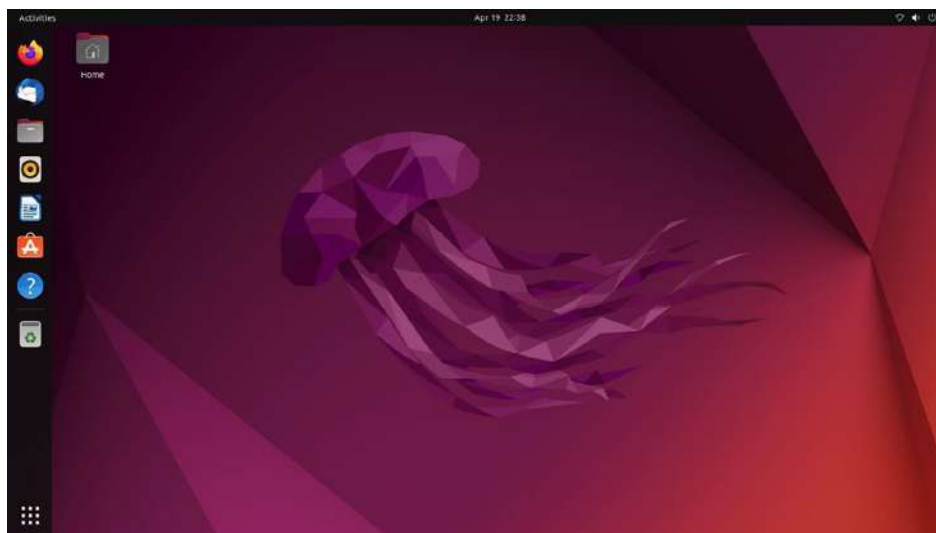


Figura 36. Interfaz de la distribución Ubuntu, de Linux

Linux es un sistema operativo completamente libre, gratuito y de código abierto, a diferencia de otros sistemas como macOS o Windows. Además, es extremadamente personalizable y se utiliza en una amplia gama de servidores, dispositivos, supercomputadoras e incluso en terminales móviles.

La comparación entre Linux y Windows ha generado una notable controversia. Si bien es cierto que Windows es el sistema operativo más atacado, esto no significa necesariamente que posea más vulnerabilidades que Linux. En este sentido, resulta importante determinar qué mitos son ciertos para obtener un panorama completo.

Dada su naturaleza de código abierto, se considera que Linux es más seguro; no obstante, aunque la comunidad de Linux reúne a un gran número de desarrolladores y desarrolladoras, más de 15000 en total, esto no garantiza que todos sean expertos en seguridad. Por tanto, dentro del *kernel* de Linux, con sus millones de líneas de código, es posible que existan vulnerabilidades, al igual que ocurre con otros sistemas operativos.

Otra afirmación común es aquella que sostiene que Linux no es susceptible de ser atacado con *malware*, lo que es totalmente falso, pues existe una gran cantidad de *malware* enfocado a este sistema operativo. Ahora bien, su cuota de mercado de usuarios/as finales es menor que la de Windows, lo que reduce el interés económico de los atacantes a la hora de dirigir sus esfuerzos hacia Linux.

En conclusión, Linux es un sistema operativo sólido y seguro, pero no está exento de vulnerabilidades ni de la posibilidad de ser objeto de ataques maliciosos. La seguridad en cualquier sistema operativo depende en gran medida de la adecuada implementación de medidas de protección y de las buenas prácticas de sus usuarios y administradores.

Distribuciones Linux

Linux cuenta con una gran variedad de distribuciones que presentan sus propias características, objetivos y enfoques, lo que le permite adecuarse a los diferentes tipos de usuarios. La elección de una u otra distribución dependerá de los requisitos específicos y de las preferencias de los destinatarios.

A continuación, describiremos las principales:

- **Debian.** Una de las distribuciones más antiguas de Linux, que ha servido como base para gran parte de las desarrolladas posteriormente. Se centra en la estabilidad y la seguridad, manifestando una filosofía de *software* libre, y actualmente cuenta con una amplia comunidad de desarrolladores/as y usuarios/as que contribuyen a su evolución y mantenimiento.



Figura 37

- **Ubuntu.** Se trata de una de las distribuciones de Linux más populares y ampliamente utilizadas en todo el mundo. Está basada en Debian y ha sido diseñada para proporcionar facilidad de uso, resultando accesible para los usuarios, tanto principiantes como experimentados. Ubuntu ofrece versiones LTS (*Long Term Support*) con soporte a largo plazo, lo que la convierte en una excelente opción para uso personal, así como para servidores y estaciones de trabajo.



Figura 38

- **Fedora.** Distribución patrocinada por Red Hat que se centra en la innovación y la adopción temprana de nuevas tecnologías. Está dirigida a usuarios más avanzados y ofrece una versión estable denominada Fedora Workstation, así como ediciones específicas para servidores y sistemas embebidos.



Figura 39

- **CentOS.** Distribución basada en el código fuente de Red Hat Enterprise Linux (RHEL). Ofrece una versión estable y a largo plazo, resultando idóneo para su uso en servidores y entornos de producción. También se centra en la compatibilidad con RHEL, lo que la convierte en una opción atractiva para quienes buscan una alternativa gratuita a dicho sistema operativo.



Figura 40

- **Arch Linux.** Distribución ligera y sumamente personalizable dirigida a usuarios avanzados y entusiastas de Linux. Utiliza un modelo de "rollos" (*rolling release*), lo que significa que se encuentra en constante desarrollo y que, en lugar de lanzar nuevas versiones, se proporcionan actualizaciones continuamente. También permite a los usuarios y las usuarias crear una instalación personalizada según sus necesidades específicas.



Figura 41

- **Kali Linux.** Se trata de la distribución de seguridad por excelencia de Linux. Ha sido diseñada específicamente para pruebas de penetración y auditorías de seguridad, de manera que cuenta con una amplia gama de herramientas de seguridad preinstaladas y *hacking* ético. Se encuentra disponible tanto para 32 bits como para 64 bits. Además, existen otras distribuciones de seguridad como Parrot Security OS, Santoku, ClearUP, etc.



Figura 42

Hemos mencionado las distribuciones más conocidas, pero existen otras muchas como Manjaro, Zorin OS, openSUSE, etc. y cada una de ellas cuenta con su propia comunidad de usuarios, además de ofrecer características únicas.

Vulnerabilidades

Aunque todos los sistemas operativos poseen vulnerabilidades, Linux presenta menos que Windows porque su uso es más limitado, lo que reduce la exposición a ataques obvios. A continuación, se describirán las vulnerabilidades conocidas más importantes de este sistema operativo:

- **Sequoia (CVE-201-33909).** Se trata de una vulnerabilidad de escalada de privilegios que afecta a la capa del sistema de archivos de Linux. Según expertos en cumplimiento y seguridad en la nube, esta vulnerabilidad se debe a un problema de tipo *size_t-to-int* en el *kernel*, lo que significa que afecta a la mayoría de los sistemas operativos. En una configuración predeterminada, cualquier usuario sin privilegios podría aprovechar esta vulnerabilidad para obtener privilegios de administrador, de modo que identificarla nos ayudará a tomar medidas para mitigar su impacto.
- **CVE-2021-33910.** Conocida como "denegación de servicio del tipo *stack exhaustion in systemd*," afecta a la utilidad *Systemd*, que se encuentra presente en la mayoría de los sistemas operativos Linux. Si esta vulnerabilidad es explotada, un usuario sin privilegios podría bloquear *Systemd* y, como resultado, el sistema operativo al completo podría verse afectado por un *kernel panic* o "ataque del pánico del *kernel*". Dado que *Systemd* es una parte fundamental del sistema operativo, esta vulnerabilidad puede repercutir significativamente en la disponibilidad y estabilidad del sistema. Para mitigarla, tendremos que actualizar a las últimas versiones de *Systemd* y mantenernos informados sobre las correcciones y los parches disponibles.
- **CVE-2022-0435.** Identificada como un desbordamiento de pila en la funcionalidad del protocolo TIPC (*Transparent Inter-Process Communication*) del *kernel* de Linux, esta vulnerabilidad se presenta cuando un usuario envía un paquete con contenido malicioso donde el número de nodos miembros del dominio es superior al límite permitido de 64. Explotarla de forma exitosa posibilitaría a un usuario remoto bloquear el sistema afectado o, en ciertos casos, incluso escalar sus privilegios si dispone de acceso a la red TIPC. Para prevenirla, resulta conveniente actualizar el *kernel* de Linux a una versión corregida y aplicar los parches de seguridad disponibles, así como restringir el acceso a la red TIPC a usuarios autorizados.
- **CVE-2022-0742.** Se trata de una fuga de memoria en la implementación de icmp6 (*Internet Control Message Protocol* versión 6) en el *kernel* de Linux que afecta específicamente a las versiones 5.13 y posteriores. Esta vulnerabilidad permite llevar a cabo un ataque remoto de denegación de servicio (DoS) en un *host* al enviar paquetes icmp6 de tipo 130 o 131. Al explotarla, el atacante puede provocar que el *host* afectado consuma una memoria excesiva y, en consecuencia, que agote los recursos disponibles, lo que puede conducir a la inestabilidad o incluso a la paralización del sistema. Como ocurre con el resto de las vulnerabilidades, resulta recomendable actualizar el *kernel* de Linux a una versión corregida y aplicar los parches de seguridad pertinentes, además de implementar medidas de filtrado y de control de tráfico.

- **CVE-2020-14305.** Fallo de escritura en memoria fuera de los límites en la funcionalidad de seguimiento de conexiones de voz sobre IP H.323 del *kernel* de Linux que ocurre cuando se manejan conexiones en el puerto ipv6 1720. Un atacante remoto y no autenticado puede aprovechar esta vulnerabilidad para bloquear el sistema objetivo, causando una denegación de servicio. Su gravedad radica en su potencial para afectar a la confidencialidad, la integridad y la disponibilidad del sistema. Mantener el *kernel* actualizado e implementar medidas de seguridad en el perímetro de la red, como *firewalls* y filtros de tráfico, nos ayudará a prevenirla.
- **CVE-2020-15436.** También conocida como *Use-after-free*, afecta al archivo *fs/block_dev.c* en el *kernel* de Linux en versiones anteriores a la 5.8. Esta vulnerabilidad permite a usuarios locales obtener privilegios no autorizados o provocar una denegación de servicio explotando un acceso indebido a un campo de error específico. En el caso de explotar esta vulnerabilidad, un atacante local podría ejecutar código malicioso con privilegios elevados en el sistema u ocasionar que este se bloquee, lo que afectaría a su disponibilidad. La principal forma de abordarla consiste en actualizar el *kernel* de Linux a una de las versiones posteriores a la 5.8, ya que estas incluyen correcciones para esta vulnerabilidad en concreto.

6.5 macOS

macOS, anteriormente conocido como OS X, es el sistema operativo desarrollado por Apple para sus ordenadores Mac. Destaca por su diseño elegante, su facilidad de uso y su perfecta integración con otros dispositivos de la marca, como iPhone, iPad y Apple Watch.

Su nacimiento se remonta a 1984, cuando Apple lanzó el Machintosh 128K, que presentaba una GUI revolucionaria. De hecho, este equipo y sus sistema operativo marcaron un punto de inflexión en la industria informática.

Con el tiempo, el sistema operativo Machintosh se convirtió en Mac OS, pasando por varias versiones hasta el año 2001, cuando Apple presentó Mac OS X, una versión completamente nueva basada en el código abierto Unix llamado Darwin. Esta versión incorporaba una interfaz más elegante y moderna, así como una estabilidad y una seguridad mejoradas. En años posteriores, experimentó varias actualizaciones y cambios de nombre hasta que, en 2016, cambió definitivamente a macOS para transmitir su integración con otros sistemas operativos de Apple como iOS y tvOS.

Una de las características distintivas de macOS es su interfaz gráfica intuitiva y amigable, que permite a los usuarios y las usuarias navegar y realizar tareas de manera sencilla y eficiente; además, ofrece diversas funciones y herramientas destinadas a mejorar la productividad y la experiencia del usuario. Este sistema operativo también destaca por su ecosistema cerrado de aplicaciones, que se distribuyen a través de la App Store de Apple, lo que garantiza un mayor control sobre su calidad y seguridad.



Figura 43. Interfaz de macOS

Entre las principales características de este sistema operativo, destacan:

- Perfecta compatibilidad con otros dispositivos de Apple, como iPad, Apple TV o iPhone, entre otros.
- Sistema de archivos propio, lo que implica que no procesa de forma nativa archivos o programas con formatos para Windows o Linux.
- Se trata del segundo sistema operativo más utilizado en el mundo, lo que se debe en gran parte a los diseños vanguardistas de los dispositivos de Apple.
- Ofrece un entorno virtual amigable e intuitivo para sus usuarios y usuarias.
- Se encuentra preinstalado en todos los ordenadores fabricados por Apple.
- Incluye *software* de uso propio, como Finder, Safari o Launchpad.
- Al igual que Microsoft Windows, se trata de un *software* comercial de código cerrado.
- Emplea un sistema de encriptado que prioriza la privacidad y la seguridad de los usuarios y las usuarias.
- De cara a su funcionamiento, utiliza procesadores de la familia Intel.

No obstante, este sistema operativo también presenta algunas desventajas, entre ellas:

- No es compatible con tantos *software* de aplicación como Microsoft Windows.
- No ofrece demasiado soporte para ejecutar videojuegos recientes.
- En caso de presentar problemas, puede resultar más complicado obtener soporte técnico que con otros sistemas operativos.
- Solo es compatible con procesadores Intel.
- Está orientado al uso doméstico y sencillo, de modo que tal vez no represente la opción más adecuada para desarrolladores/as y usuarios/as con necesidades informáticas avanzadas.

Versiones del sistema operativo

Aunque a lo largo de los años se han desarrollado numerosas versiones, solo mencionaremos las principales, junto con algunas de sus características:

- **macOS X 10.0 Cheetah (2001).** Primera versión de macOS basada en Unix. Introdujo la interfaz Aqua, con animaciones y efectos visuales, e incluía aplicaciones como iTunes, Mail y QuickTime.
- **macOS X 10.4 Tiger (2005).** Introdujo el motor Spotlight, destinado a una búsqueda rápida de archivos, así como el navegador web Safari y Dashboard con *widgets*. Además, incorporaba la función de Exposé para gestionar ventanas y aplicaciones abiertas.

- **OS X 10.7 Lion (2011).** Incorporó el gesto de deslizamiento con el *trackpad* y el lanzamiento de Mission Control, junto con soporte para aplicaciones a pantalla completa y la función de resumen de aplicaciones para guardar y restaurar su estado.
- **OS X 10.9 Mavericks (2013).** En esta versión, se incluyó la función de etiquetado, destinada a organizar archivos y carpetas, se incorporó la aplicación Maps para visualizar mapas y direcciones y se mejoró la duración de la batería y el rendimiento del sistema.
- **macOS 10.12 Sierra (2016).** Incorporaba la función de desbloqueo automático con el Apple Watch y el asistente virtual Siri en el escritorio. Además, ofrecía la opción de copiar y pegar entre dispositivos Apple.
- **macOS 10.15 Catalina (2019).** En esta versión, se eliminó iTunes, que se reemplazó por aplicaciones independientes (Apple Music, Apple TV y Apple Podcasts) y se incorporó Sidecar, que permitía utilizar el iPad como segunda pantalla. Asimismo, se mejoró la seguridad y la privacidad por medio de los controles de autorización de aplicaciones.
- **macOS 11 Big Sur (2020).** Esta versión estableció el cambio de numeración a macOS 11 para alinearse con las versiones de iOS. En ella, se rediseñó la interfaz para aportarle un aspecto más moderno y coherente con otros dispositivos Apple y se incorporó el centro de control, que proporcionaba un rápido acceso a configuraciones y controles.
- **macOS 12 Monterey (2021).** Entre sus principales características, destacan la función *Universal Control* para compartir el teclado y el *mouse* entre un Mac y un iPad, así como la función *AirPlay to Mac* para transmitir contenido desde un dispositivo iOS a un Mac. Paralelamente, se perfeccionó la funcionalidad de *FaceTime* con el modo retrato, así como la opción de compartir pantalla con otras personas.

Hasta la fecha, la última versión disponible en el mercado es macOS 14 *Sonoma*, que incluye mejoras en iMessage, unos *widgets* renovados, un nuevo modo de juego que optimiza el rendimiento del equipo, etc.

Vulnerabilidades

Aun cuando históricamente ha sido considerado uno de los sistemas operativos más seguros por su arquitectura Unix y por el enfoque de Apple en la privacidad y la seguridad, macOS no está exento de vulnerabilidades ni es inmune a posibles ataques y *exploits*:

- **CVE-2022-32893.** Vulnerabilidad que afecta a WebKit, el motor de navegación web utilizado por Safari y por otras aplicaciones en sistemas macOS e iOS. Se trata de un *bug* en WebKit que permite a un atacante acceder a contenido web malicioso o procesarlo, lo que puede conducir a una ejecución arbitraria de código en el sistema afectado. Por tanto, un atacante podría crear un sitio web malicioso o enviar un enlace que, al ser visitado por un usuario vulnerable, ejecute un código malicioso en el sistema sin su conocimiento o consentimiento.
- **CVE-2022-32894.** Se beneficiaba de un fallo de seguridad en el *kernel* del sistema operativo para ejecutar código malicioso con todo tipo de privilegios. Si un atacante lograra explotar una vulnerabilidad en el *kernel*, podría sortear las protecciones y restricciones de seguridad y ejecutar código malicioso con los máximos privilegios del sistema.

- **CVE-2021-1834.** Problema de escritura fuera de los límites que se ha corregido en macOS *Big Sur* 11.3, actualización de seguridad 2021-002 *Catalina* y actualización de seguridad 2021-003 *Mojave*. En este caso, una aplicación maliciosa podría ejecutar código arbitrario con privilegios de *kernel*.
- **CVE-2021-30793.** Problema de escritura fuera de los límites en el *kernel* del sistema operativo macOS. Un error en la comprobación de límites permitiría a una aplicación maliciosa realizar operaciones de escritura más allá de los límites asignados en el *kernel*. El problema se ha resuelto en macOS *Big Sur* 11.5, actualización de seguridad 2021-004 *Catalina* y actualización de seguridad 2021-005 *Mojave*.
- **CVE-2020-27914.** Problema de corrupción de memoria en el sistema operativo macOS. Un error en la validación de entrada permitiría que una aplicación maliciosa cause corrupción en la memoria del sistema. Como ocurría con la vulnerabilidad anterior, el problema se solventó en macOS *Big Sur* 11.1, actualización de seguridad 2020-001 *Catalina* y actualización de seguridad 2020-007 *Mojave*, macOS *Big Sur* 11.0.1.